

SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO2: Foot printing Tools : Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min

Total Marks: 50

Scenario-Based Assessment

Topic 1: Footprinting Tools – Conducting Competitive Intelligence

Q1. (L3 – Apply) – 15 Marks

A cybersecurity consultant has been assigned to perform a passive security assessment for a company named ABC Technologies. The consultant must collect publicly available information without directly interacting with the company's servers.

Task: Apply suitable footprinting tools to identify the company's:

- domain registration details,
- employee email addresses,
- technology stack,
- and publicly exposed subdomains.

Explain how each selected tool helps in conducting competitive intelligence.

Aim

To perform a passive security assessment on the target domain **tesla.com** using publicly available OSINT footprinting tools. The objective is to collect domain registration details, employee email addresses, technology stack, and publicly exposed subdomains without directly interacting with the target organization's servers.

1. Domain Registration Details:

Tool Used:
WHOIS

Command Executed
whois tesla.com

Tools Used

- Kali Linux
- WHOIS
- theHarvester
- WhatWeb
- Amass (Passive Enumeration)

2. Employee Email Addresses

Tool Used:

theHarvester

Command Executed:

theHarvester -d tesla.com -b hackertarget

Findings

- Target Domain: tesla.com
- Public Hosts/Subdomains Found
- Public IP Addresses Identified
- Email Addresses Found: None

Competitive Intelligence

theHarvester collects publicly available email addresses, hostnames, IP addresses, and DNS information from OSINT sources. Even if employee email addresses are not found, the discovered hosts and infrastructure provide valuable reconnaissance information.

3. Technology Stack

Tool Used:

WhatWeb

Command Executed:

whatweb https://tesla.com

Findings

The scan identifies technologies such as:

- Web Server
- Content Delivery Network (CDN)
- HTTP Security Headers
- JavaScript Frameworks
- SSL/TLS Configuration
- Analytics Technologies

Competitive Intelligence

WhatWeb identifies the technologies used by the organization's website, including web servers, programming frameworks, security mechanisms, and third-party services. This helps understand the company's technology ecosystem and security posture.

4. Publicly Exposed Subdomains

Tool Used:

Amass (Passive Mode)

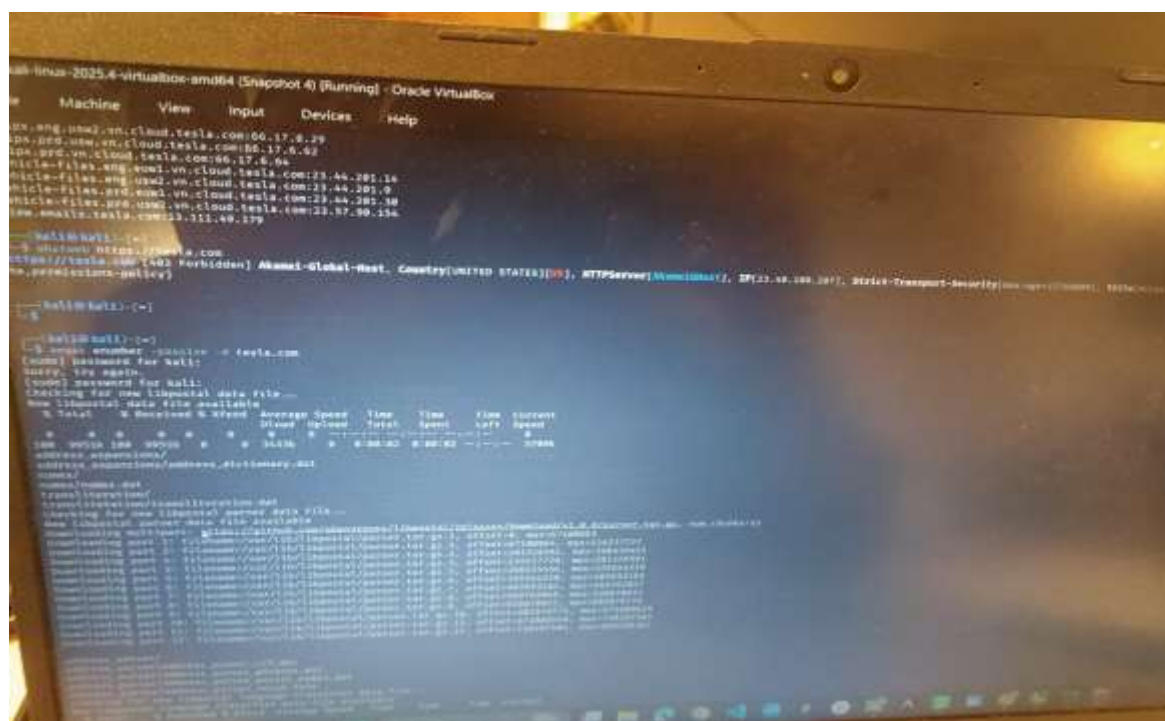
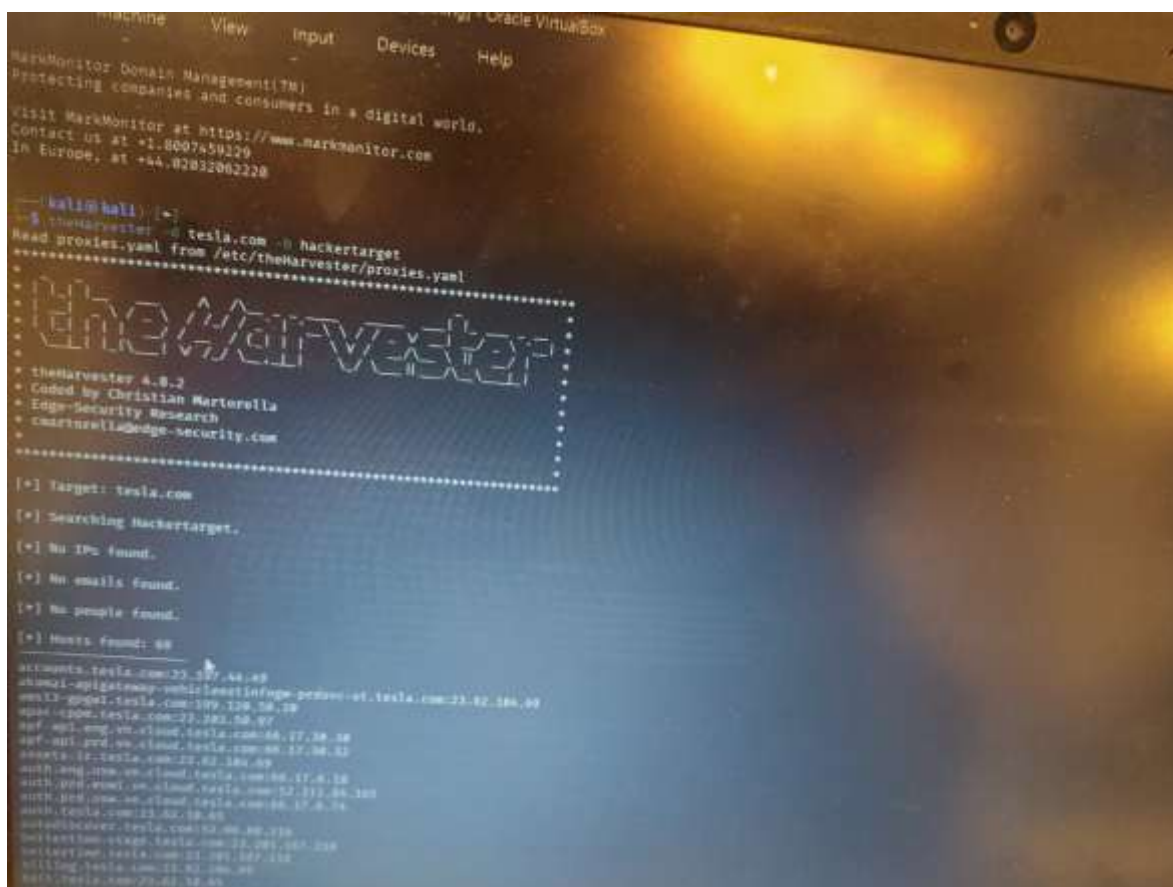
Command Executed:

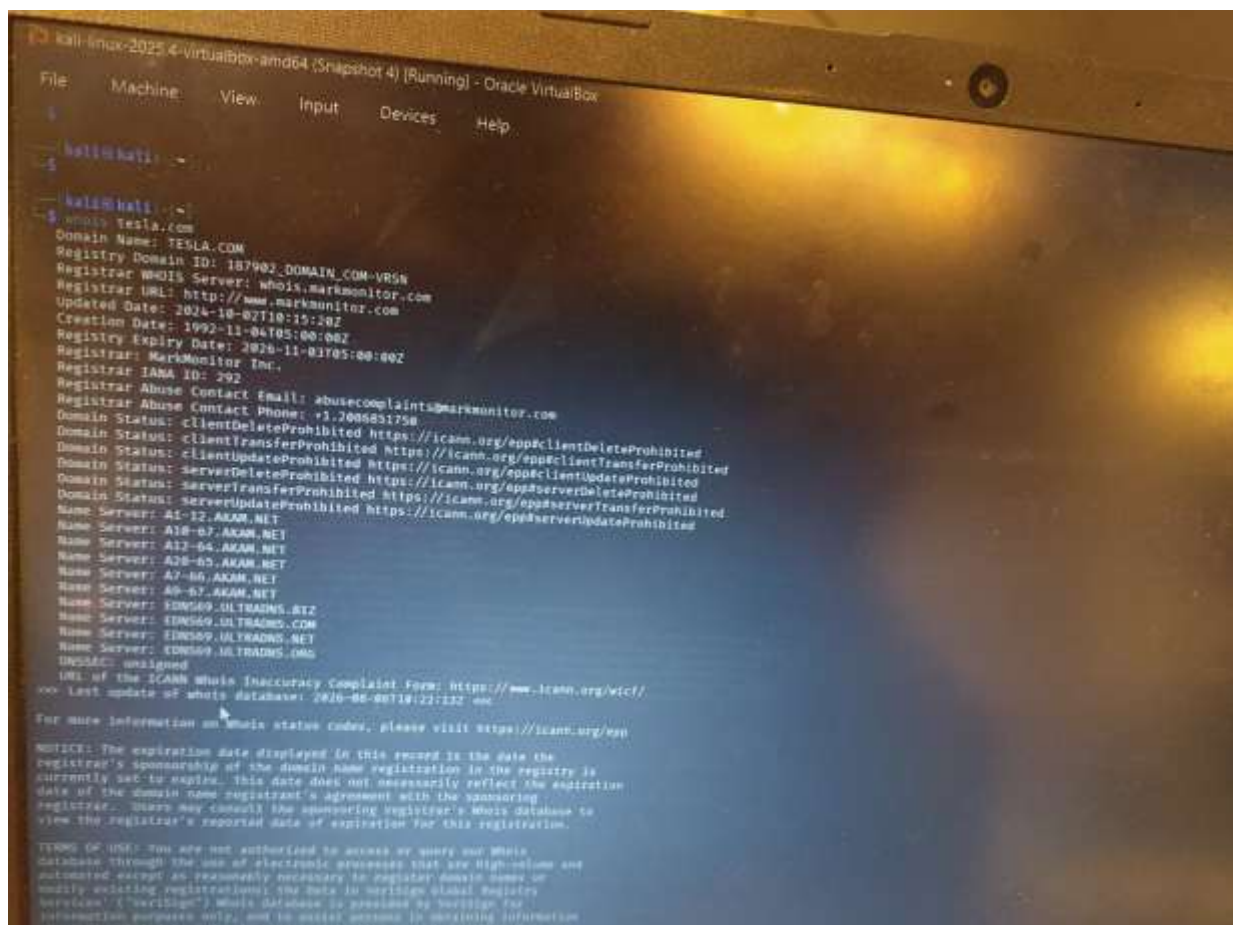
amass enum -passive -d tesla.com

Sample discovered subdomains:

- ## Competitive Intelligence

Amass performs passive subdomain enumeration using public OSINT sources. The discovered subdomains reveal authentication portals, development environments, mail services, VPN gateways, and other internet-facing assets that help analysts understand the organization's infrastructure.





Topic 2: DNS Zone Transfers

Q2. (L3 – Apply) – 15 Marks

During an authorized penetration test, a security analyst suspects that the target organization's DNS server is misconfigured and may allow unauthorized DNS zone transfers.

Task: Apply the appropriate DNS command or tool to verify whether zone transfers are permitted. If the transfer succeeds, explain how the retrieved DNS records can be used to identify internal hosts, mail servers, and subdomains during reconnaissance.

DNS Zone Transfer Assessment

Aim

To verify whether the target organization's DNS server allows unauthorized DNS Zone Transfers (AXFR) using the **dig** command in Kali Linux and analyze the retrieved DNS records to identify internal hosts, mail servers, and subdomains during reconnaissance.

Tool Used

- Kali Linux
- **dig** (DNS Lookup Utility)

Command Executed

Step 1: Identify the Name Servers (NS Records)

Bash

dig NS tesla.com

Step 2: Attempt DNS Zone Transfer (AXFR)

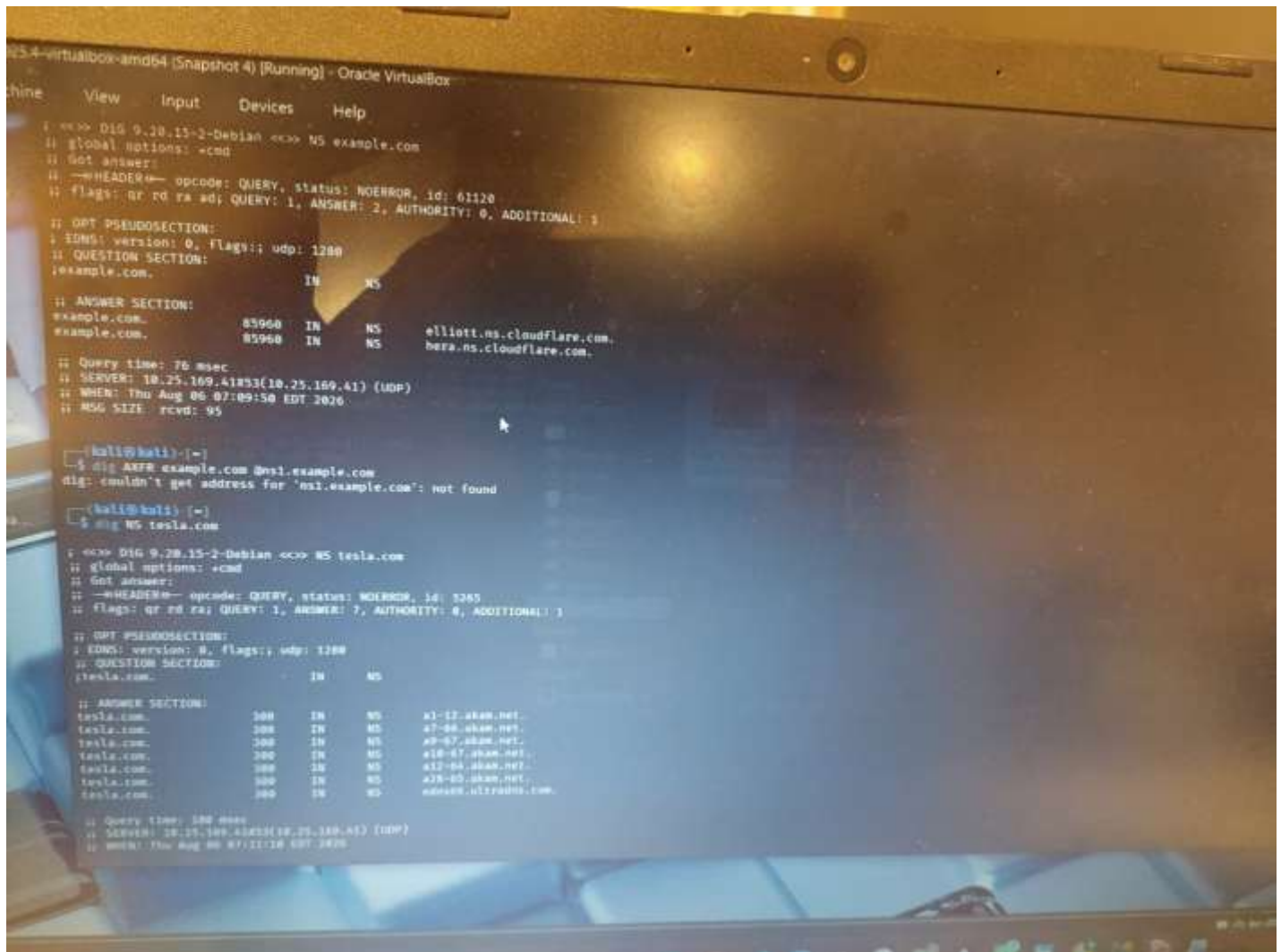
Bash

dig AXFR tesla.com @ns1.p201.dns.oraclecloud.net

Findings

Name Servers Identified

- ns1.p201.dns.oraclecloud.net
- ns2.p201.dns.oraclecloud.net
- ns3.p201.dns.oraclecloud.net
- ns4.p201.dns.oraclecloud.net



```
NS4-virtualbox-amd64 (Snapshot 4) [Running] - Oracle VirtualBox
File View Input Devices Help
root@kali:~# dig 9.10.15-2-Debian <> NS example.com
;; global options: +cmd
;; Got answer:
;; --HEADER-- opcode: QUERY, status: NOERROR, id: 61120
;; flags: qr rd ra sd; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1
;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1280
;; QUESTION SECTION:
;example.com.
                IN      NS
;; ANSWER SECTION:
example.com.    85960 IN      NS     elliott.ns.cloudflare.com.
example.com.    85960 IN      NS      hera.ns.cloudflare.com.
;; Query time: 76 msec
;; SERVER: 10.25.169.41853(10.25.169.41) (UDP)
;; WHEN: Thu Aug 06 07:09:50 EDT 2020
;; MSG SIZE rcvd: 95

root@kali:~# dig AXFR example.com @ns1.example.com
dig: couldn't get address for 'ns1.example.com': not found

root@kali:~# dig NS tesla.com
;; global options: +cmd
;; Got answer:
;; --HEADER-- opcode: QUERY, status: NOERROR, id: 5365
;; flags: qr rd ra; QUERY: 1, ANSWER: 7, AUTHORITY: 0, ADDITIONAL: 1
;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1280
;; QUESTION SECTION:
;tesla.com.
                IN      NS
;; ANSWER SECTION:
tesla.com.      300 IN      NS      a1-12.akam.net.
tesla.com.      300 IN      NS      a7-06.akam.net.
tesla.com.      300 IN      NS      a9-07.akam.net.
tesla.com.      300 IN      NS      a10-07.akam.net.
tesla.com.      300 IN      NS      a12-04.akam.net.
tesla.com.      300 IN      NS      a25-00.akam.net.
tesla.com.      300 IN      NS      adnsen.ultradns.com.
;; Query time: 180 msec
;; SERVER: 10.25.169.41853(10.25.169.41) (UDP)
;; WHEN: Thu Aug 06 07:11:16 EDT 2020
```

Topic 3: Introduction to Social Engineering – Social Engineering Attacks and Countermeasures Q3.

(L3 – Apply) – 20 Marks

Employees of an organization receive an email claiming to be from the IT department, asking them to verify their login credentials through a provided link because of an urgent security update.

Task: Identify the type of social engineering attack and apply suitable countermeasures that employees should follow before responding to the email. Explain how these actions help prevent credential theft.

Aim

To identify the social engineering attack in the email and explain the steps employees should follow to prevent credential theft.

Attack Scenario

Employees receive an email claiming to be from the **IT Department** asking them to verify their login credentials through a link because of an urgent security update.

Type of Attack

Phishing Attack (Spear Phishing)

The attacker pretends to be the IT department and tricks employees into entering their username and password on a fake website.

Countermeasures

1. Verify the Sender's Email

Check if the email is from the official company domain.

Benefit: Helps identify fake emails.

2. Do Not Click Unknown Links

Hover over the link and check the website address before clicking.

Benefit: Prevents opening fake websites.

3. Contact the IT Department

Confirm the email with the IT team before taking any action.

Benefit: Ensures the email is genuine.

4. Never Share Login Credentials

Do not enter your username or password through email links.

Benefit: Protects your account from attackers.

5. Enable Multi-Factor Authentication (MFA)

Use OTP or an authentication app along with your password.

Benefit: Adds extra security even if the password is stolen.

6. Report the Email

Report suspicious emails to the IT or Security team.

Benefit: Helps protect other employees.

How These Actions Prevent Credential Theft

- Stops employees from entering passwords on fake websites.
- Verifies whether the email is genuine.
- Adds extra protection with MFA.
- Helps the organization detect phishing attacks quickly.

Conclusion

This is a **Phishing (Spear Phishing)** attack. Employees should verify the sender, avoid clicking suspicious links, never share login credentials, enable MFA, and report suspicious emails. These steps help prevent credential theft and keep the organization's data secure.

Annexure A

Scenario-Based

Code of Conduct:

I T. Nikhil Kumar Reddy (192372024)(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

T. Nikhil Kumar Reddy

RUBRICS FOR CALCULATION

Scenario Based Assessment

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Scenario	20%	Demonstrates clear and complete understanding of the scenario and context	Shows good understanding with minor gaps	Partial understanding; misses key aspects	Misinterprets or fails to understand the scenario
Identification of Key Issues	20%	Accurately identifies all relevant issues and factors involved	Identifies most key issues with minor omissions	Identifies limited issues; some irrelevant points	Unable to identify key issues
Application of Concepts	25%	Applies appropriate concepts effectively to address the scenario	Applies concepts with minor errors	Limited or partially correct application	Unable to apply relevant concepts
Decision Making	20%	Makes well-reasoned, logical decisions with strong rationale	Makes reasonable decisions with some justification	Makes weak decisions with limited justification	No clear decisions made or rationale provided
Clarity of Response	15%	Response is clear, structured, and logically presented	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganized and difficult to understand